



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Laboratorio di Sicurezza Informatica

Monitoraggio

Marco Prandini

Dipartimento di Informatica – Scienza e Ingegneria

Finalità

- Le fasi di un attacco possono lasciare tracce.
- Individuarle con accuratezza e tempestività è di fondamentale importanza per evitare o limitare danni.



I termini del monitoraggio

■ IDS = Intrusion Detection System

- è genericamente un sistema in grado di rilevare tentativi di attacco
 - *signature based* (riconosce attacchi noti)
 - *anomaly detection* (riconosce deviazioni dall'uso standard)

■ IPS = Intrusion Prevention System

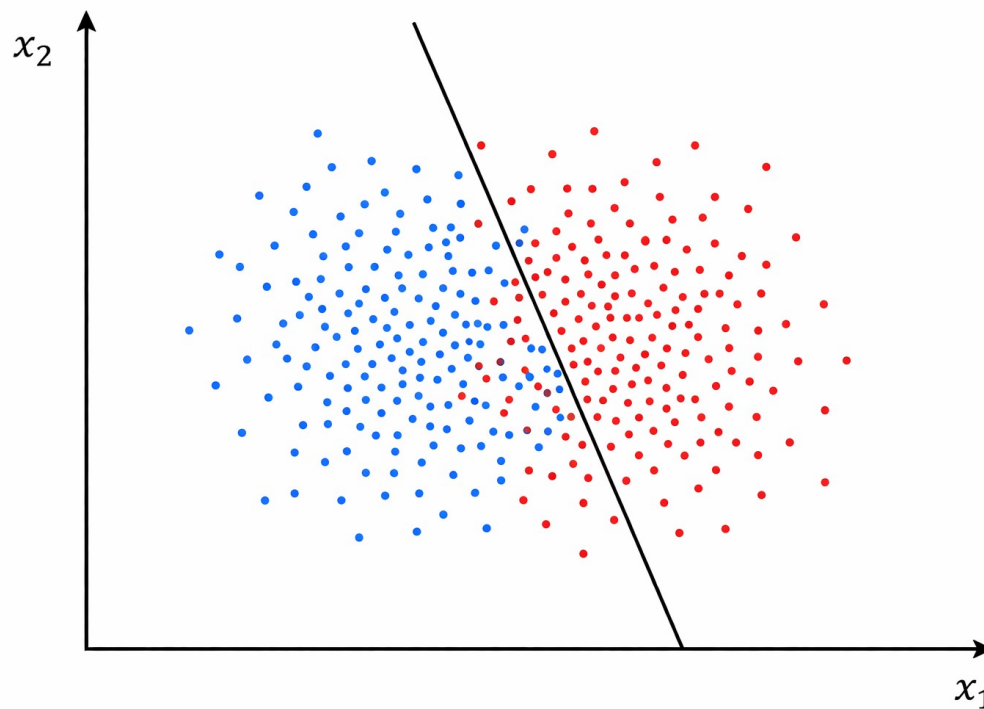
- semplificando: un IDS in grado di interagire con sistemi di controllo dell'accesso per bloccare il traffico malevolo

■ SIEM = Security Information and Event Management

- piattaforma che integra strumenti, politiche e procedure per la gestione integrata delle fonti di informazione e degli incidenti

Parametri di qualità del rilevamento degli eventi

- **Falso positivo (FP)**: segnalazione di attacco errata da evento innocuo
- **Falso negativo (FN)**: attacco reale che non genera una segnalazione
- La scelta di un criterio di classificazione è tipicamente un compromesso



NIDS, HIDS, EDR

■ Due strategie di rilevazione

- Basate sulla rete
 - **NIDS / Network-based IDS**
- Basate sull'endpoint
 - **HIDS / Host-based IDS**
 - **EDR / Endpoint Detection and Response**

■ NIDS usa i dati intercettati sui canali di comunicazione

- sistema dedicato sul perimetro o con sonde, per il traffico di tutti i sistemi

■ HIDS è un processo userland sul sistema da proteggere

- vede il traffico diretto a un singolo sistema
- monitora il filesystem, i processi, le attività utente
- esamina in tempo reale i log file
- verifica periodicamente contenuti e metadati dei file

■ EDR può essere definito come un HIDS fortemente integrato col sistema operativo

NIDS

■ Vantaggi

- Visibilità di tutto il traffico, entrante e uscente
- Richiede un solo punto di installazione
 - vero solo se rete semplice (dispositivi mobili che lasciano la rete??)
 - con più sonde: possibilità di ragionare su flussi
- Un malfunzionamento non incide sugli endpoint

■ Svantaggi

- Maggior tasso di FP
 - processi legittimi possono generare occasionalmente traffico anomalo
- Più soggetto a sovraccarico o evasione
 - es. pacchetti frammentati
- Non può esaminare il traffico cifrato
- Un punto di analisi per un'intera rete → richieste hardware
 - < 20-30 Mbps: raspberry PI
 - < 200-300 Mbps: pc desktop di un paio d'anni
 - < 1 Gbps: server almeno 8 core / 16 thread
 - > 10 Gbps: 40+ core e probabilmente serve accelerazione hardware

HIDS

■ Vantaggi:

- Minor tasso di FP
 - Pacchetti di rete sospetti possono essere correttamente classificati solo esaminando l'interazione con l'obiettivo finale
- Economico
 - Sfrutta per definizione i sistemi già esistenti
 - Non molto impegnativo computazionalmente (distribuito)

■ Svantaggi

- Punti ciechi
 - Se un evento/pacchetti non lascia tracce sul filesystem è invisibile
 - Non valuta il traffico uscente (**egress**) – solo entrante (**ingress**)
 - Non individua scansioni che non toccano servizi attivi
- Richiede l'installazione di un agente sulla macchina
- Se la macchina è compromessa può essere neutralizzato

EDR

■ Vantaggi su HIDS

- in grado di raccogliere eventi dai device driver di filesystem e di rete e comunicazioni interprocesso
- in grado di analizzare eseguibili e librerie al caricamento e a run time (system call, fork)
- capacità anti-tampering
- maggiori possibilità di risposta (isolamento di comunicazioni e di processi)

■ Svantaggi

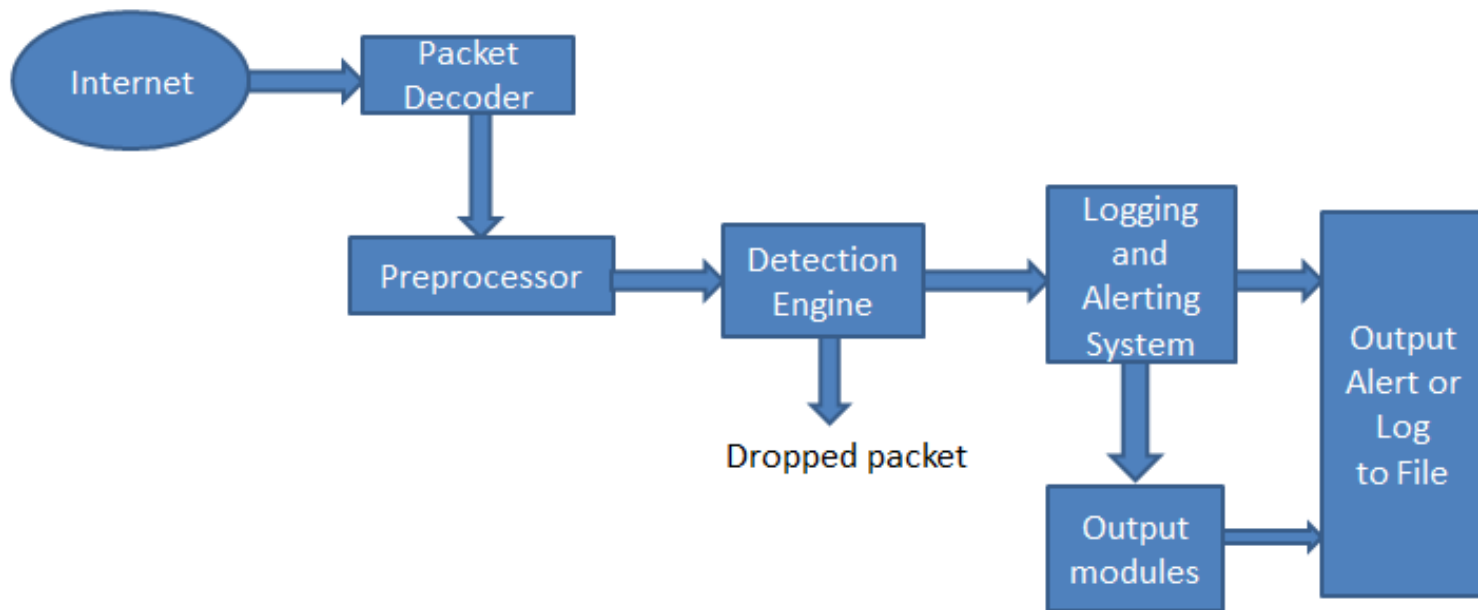
- richiede interfacciamento stretto con OS (non così ovvio)
 - hooking
 - minifilters
- difficile trovare soluzioni open e non molto costose

Network IDS

- La rilevazione di attacchi che giungono via rete viene svolta analizzando il traffico in entrata/uscita
- Problema essenziale:
 - esaminare tutto il traffico senza rallentarlo
 - generando pochissimi falsi allarmi
 - senza lasciar sfuggire attacchi reali
- Due approcci:
 - Signature based: rileva flussi con caratteristiche notoriamente malevole
 - Anomaly based: rileva flussi che si discostano dalla “normalità”
- Tra i più diffusi
 - Snort
 - Suricata
 - Zeek (ex Bro)

SNORT

■ <http://www.snort.org/>



SNORT

■ Architettura di base:

- Libpcap-based sniffing interface
 - cattura i pacchetti e li salva in un formato standard per l'analisi successiva
- Rules-based detection engine
 - possibilità di utilizzare un vasto set di regole già pronte e di personalizzarle
- Plug-in system
 - funzionamento estendibile aggiungendo moduli

- ## ■ CAVEAT: Snort è uno strumento potente, ma per massimizzare la sua efficacia serve una competenza specifica ed un lungo affinamento della configurazione
- stima dell'autore originale: 12 mesi di formazione per acquisire i fondamenti di intrusion detection, 24-36 mesi per diventare esperti

Suricata

<https://suricata-ids.org/>

■ Configurazione:

- Implementa un linguaggio per la rilevazione di signature
 - Compatibile con SNORT
- Può essere configurato per rilevare anomalie
- Può essere esteso con LUA per processing oltre la capacità del linguaggio a regole

■ Caratteristiche di funzionamento particolari:

- Riconosce automaticamente il tipo di traffico e adatta il dettaglio dei log
 - es. salva i certificati X.509 usati nelle connessioni TLS
 - salva l'header a livello applicazione per i protocolli più comuni
 - Deep Packet Inspection

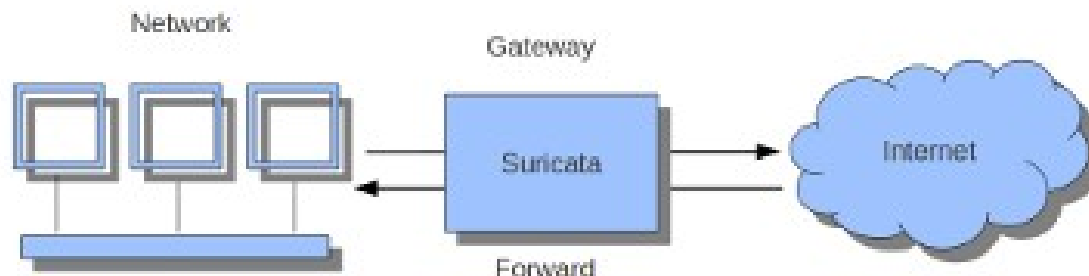
■ Output facilmente integrabile con molti strumenti di analisi e visualizzazione

■ Molte fonti gratuite di signature

- Emerging Threats
- Talos
- Positive Technology

Suricata

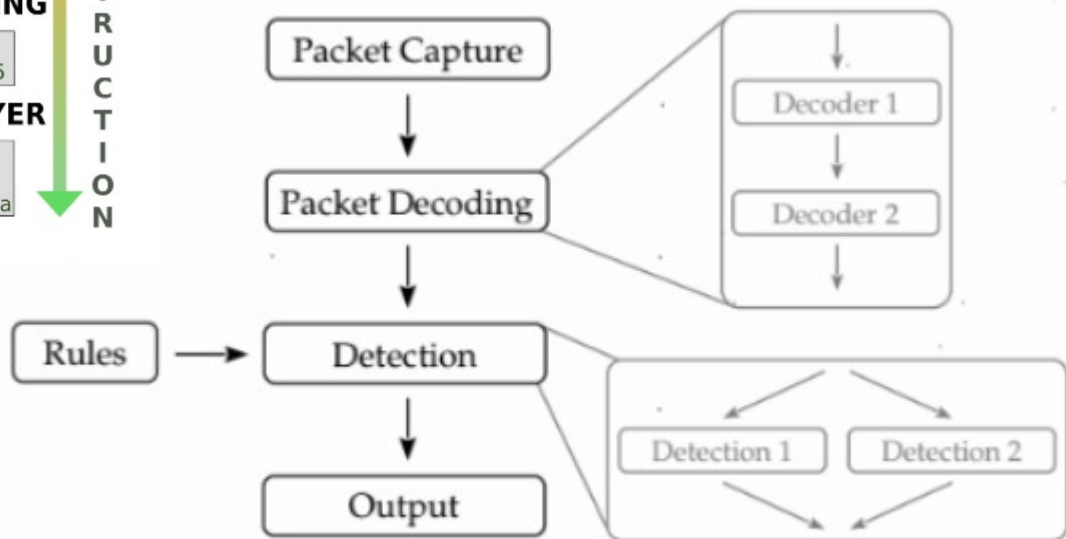
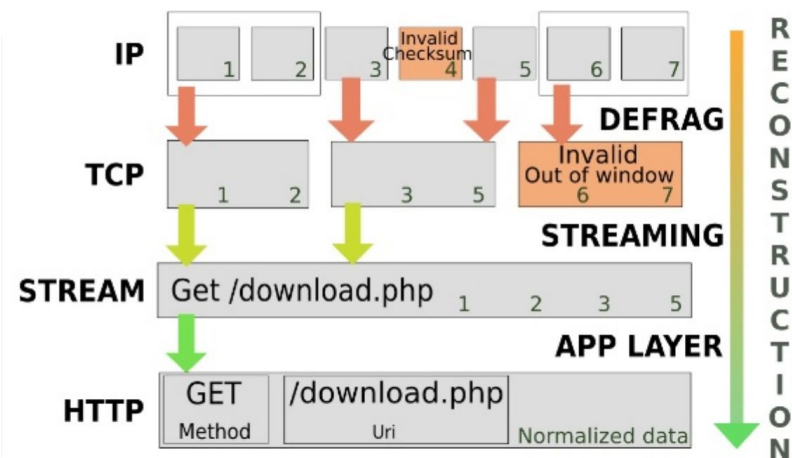
- Suricata può agire da IPS (Intrusion Prevention System)
 - Se interposto tra due reti, può non inoltrare il traffico malevolo



- Regole di pattern matching sul traffico
- Possibilità di operare "sul filo"
 - interfaccia in promiscuous mode
- Possibilità di operare "offline"
 - alimentato da file *pcap*
 - i file possono essere generati in tempo reale da probe integrate su apparati di rete o su host

Suricata

- Sistema modulare per ricostruzione, decodifica ed estrazione dei dati dai pacchetti e successiva classificazione



Zeek

<https://zeek.org/>

- Decodifica vari protocolli applicativi (HTTP, SSL, DNS, SMB e molti altri)
- Analizza TUTTO il traffico
 - Non utilizza le firme per individuare traffico malevolo
- Ha un motore di scripting molto potente:
 - per estrarre file interessanti
 - usa filtri di Bloom per cercare corrispondenze “intelligenti”
 - supporta la geolocalizzazione
 - blocco attivo della connessione chiamando API del firewall
 - calcolo dell'entropia su letture e scritture SMB per rilevare i ransomware mentre cifrano i file